



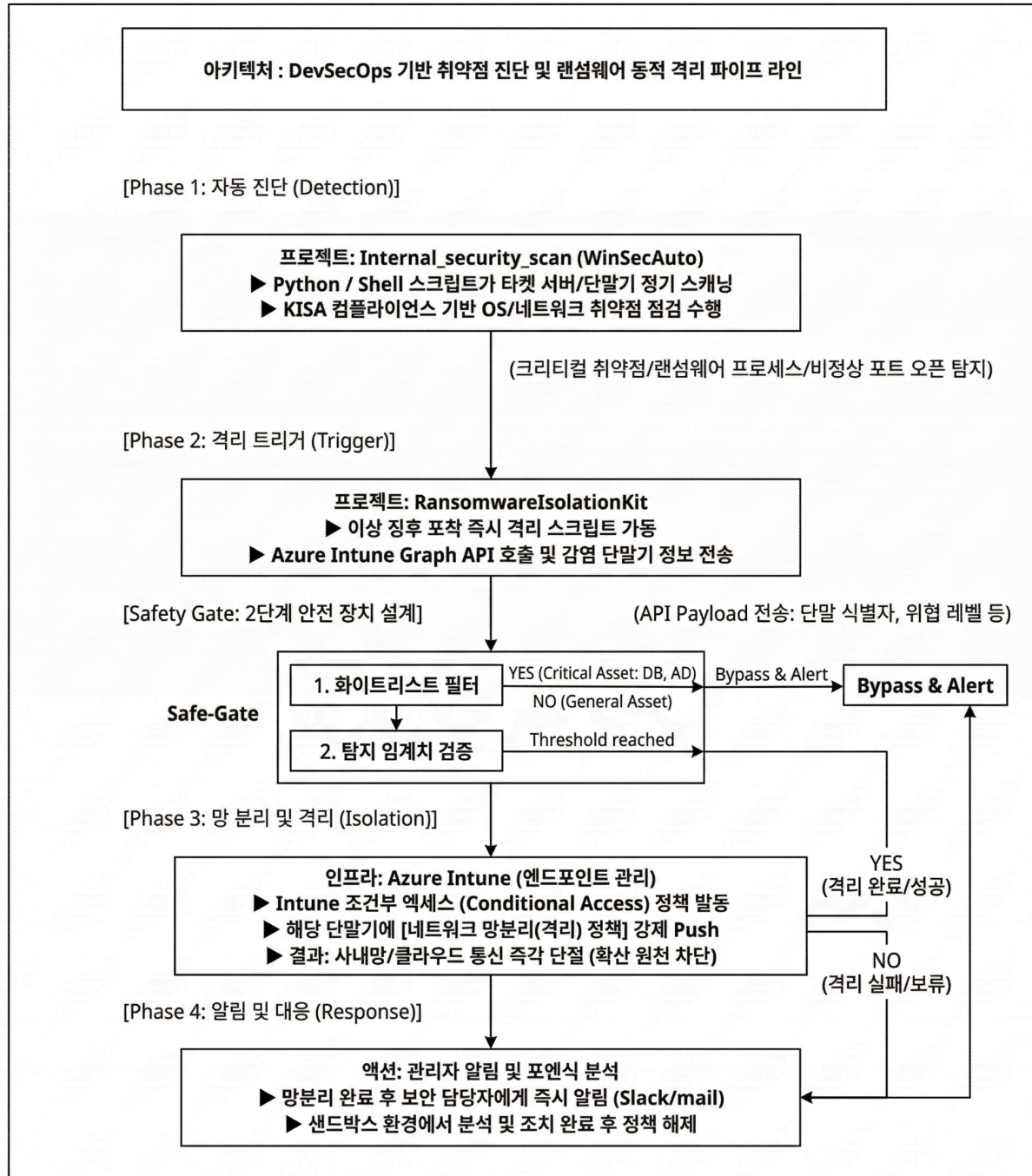
[정보보안 운영 및 컴플라이언스 보안 점검 자동화 경험] 박도윤_포트폴리 오

깃허브 링크 및 포트폴리오 :

<https://github.com/hwan1193?tab=repositories>

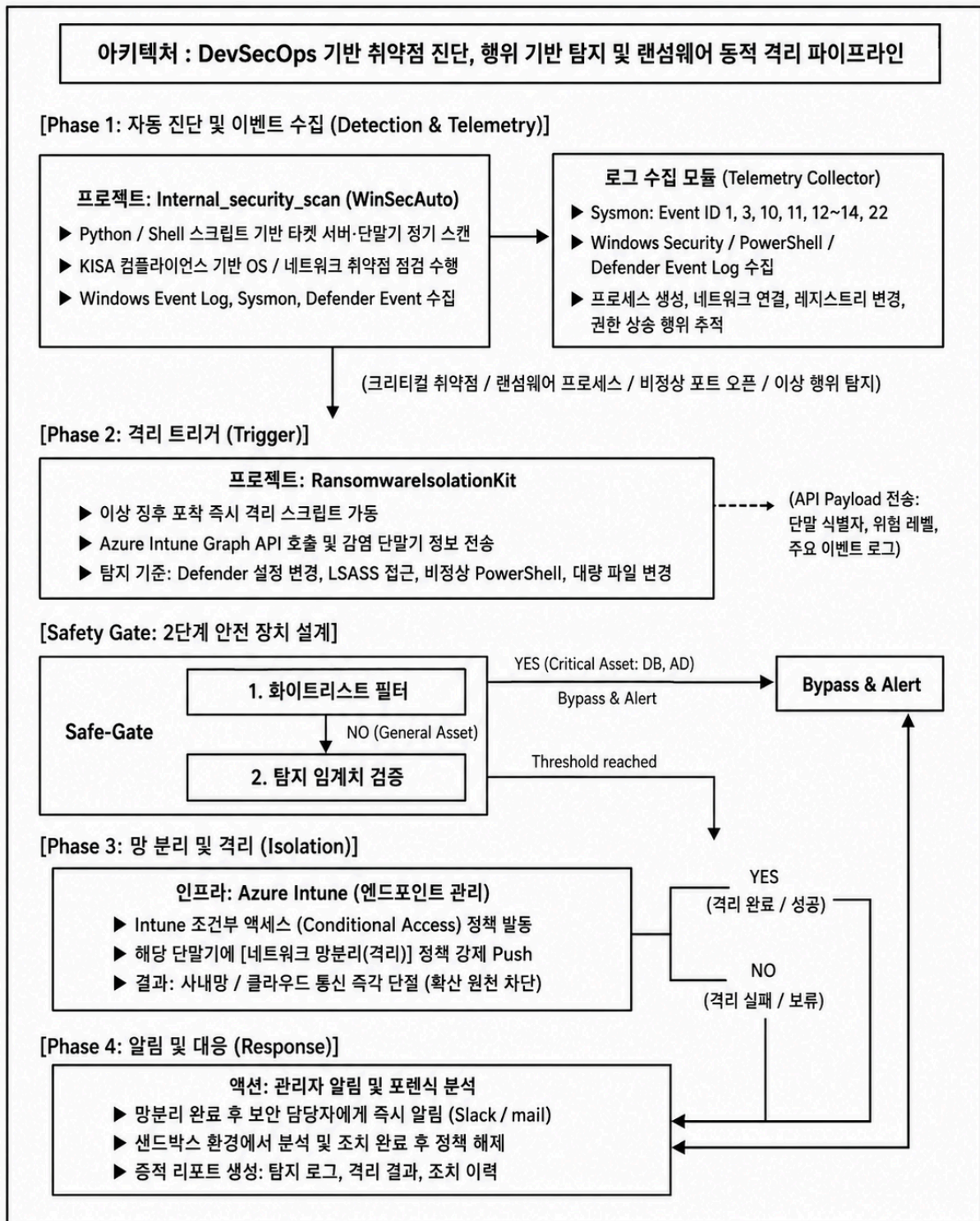
[Before] WinSecAuto 기존 구조

KISA 기반 정적 취약점 진단 및 랜섬웨어 격리 자동화 중심의 초기 설계



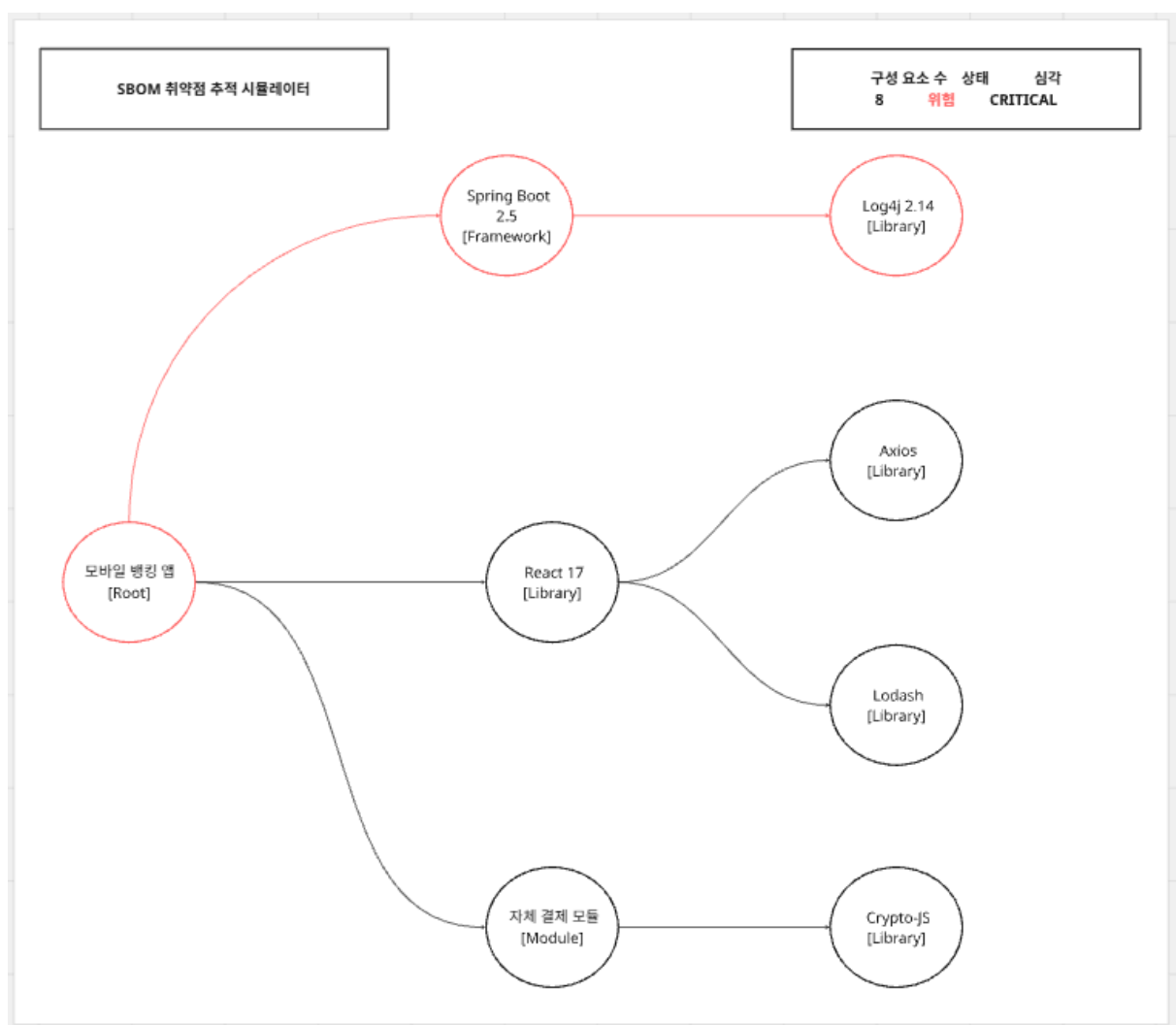
[After] WinSecAuto Behavior Engine

Sysmon·Windows Event Log·Defender Event 기반 행위 탐지와 Intune 연동 격리까지 확장한 보안 자동화 설계

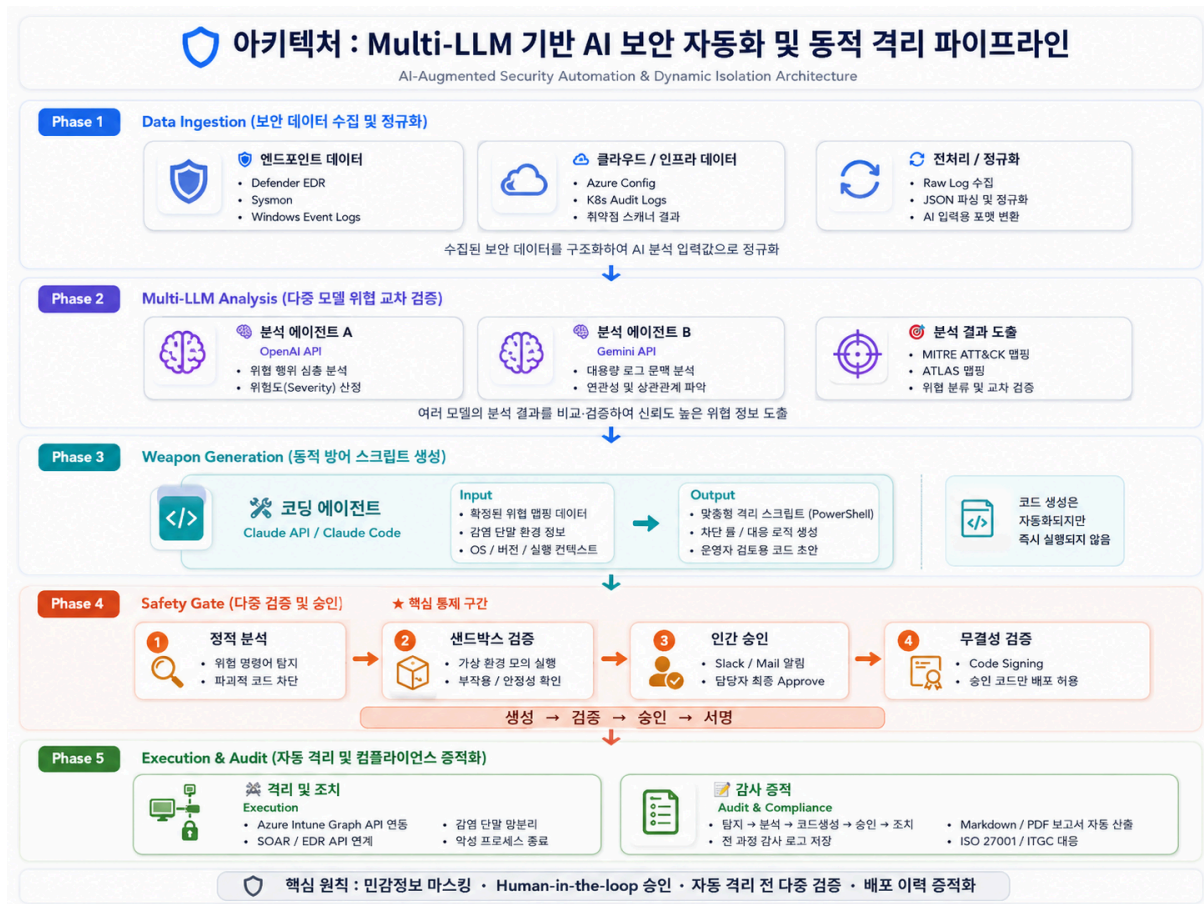


[별도 PoC] SBOM 기반 오픈소스 취약점 영향도 추적 시뮬레이터

애플리케이션 구성요소 간 의존성과 취약 라이브러리 영향 범위를 시각화한 DevSecOps 보안 분석 PoC



[Before 프로젝트명] 멀티 LLM 기반 AI 보안 자동화 및 동적 격리 파이프라인
(WinSecAuto V2.0)



진행 기간 : 2026. 05 ~ (진행 중 / PoC 설계 완료)

사용 기술 : OpenAI API, Gemini API, Claude API, PowerShell, Azure Intune Graph API, Slack Webhook, MITRE ATT&CK / ATLAS

[프로젝트 개요]

기존 룰 (Rule) 기반 보안 점검의 한계를 극복하기 위해, 다중 AI 모델 (Multi-LLM)을 활용한 위협 교차 검증 및 동적 방어 스크립트 자동 생성 체계를 설계했습니다.

특히 AI의 한계 및 보안 위협을 통제하기 위해 '4단계 Safety Gate (정적 분석, 샌드박스, 휴먼 승인, 무결성 서명)'를 도입하여 실무 적용이 가능한 안전한 DevSecOps 아키텍처를 고안했습니다.

[핵심 성과]

- 다중 LLM 교차 검증 기반 위협 탐지 (Phase 1~2)
 - Defender EDR 및 클라우드 (Azure, K8s) 인프라의 Raw Log를 JSON으로 정규화하여 수집 파이프라인 구축.
 - OpenAI와 Gemini API를 융합하여 단일 모델의 편향을 최소화하고, 탐지된 위협을 MITRE ATT&CK 및 ATLAS 프레임워크 기준으로 자동 맵핑하는 로직 설계.
- AI 동적 방어 스크립트 생성 (Phase 3)
 - 분석된 위협 데이터와 타겟 엔드포인트 환경 (OS 버전 등)을 Claude API에 연동하여, 맞춤형 격리 스크립트 (PowerShell) 및 차단 룰을 실시간 동적 생성.
- AI 리스크 통제 파이프라인 'Safety Gate' 설계 (Phase 4) ★ 핵심 포인트!
 - 생성된 코드의 위험성을 통제하기 위해 [정적 명령어 필터링 → 샌드박스 모의 실행 → Slack 봇 기반 보안 담당자 승인(Human-in-the-loop) → 디지털 코드 서명]으로 이어지는 4단계 무결성 검증 아키텍처 설계.
- 컴플라이언스 증거 자동화 (Phase 5)
 - Azure Intune 연동을 통한 단말 격리 조치 수행 및 '탐지-검증-조치' 전 과정을 Markdown/PDF 형태로 감사 증거 보고서 자동 생성하여 ISMS 및 ITGC 대응 확보 강화.

1단계 : AI 분석 리포트 자동 생성

- WinSecAuto 결과
- Defender/Sysmon/Event Log
- Trivy/OSquery/Nmap 결과
- Claude/OpenAI/Gemini 중 1개 또는 2개로 요약/위험도/조치 권고 생성

2단계 : Multi-LLM 교차 검증

- OpenAI : 위협 해석
- Gemini : 긴 로그/문서 분석
- Claude : 대응 스크립트 초안 생성

3단계 : Safety Gate

- 위험 명령어 필터링
- 샌드박스 실행
- 관리자 승인
- 코드 서명 또는 해시 검증

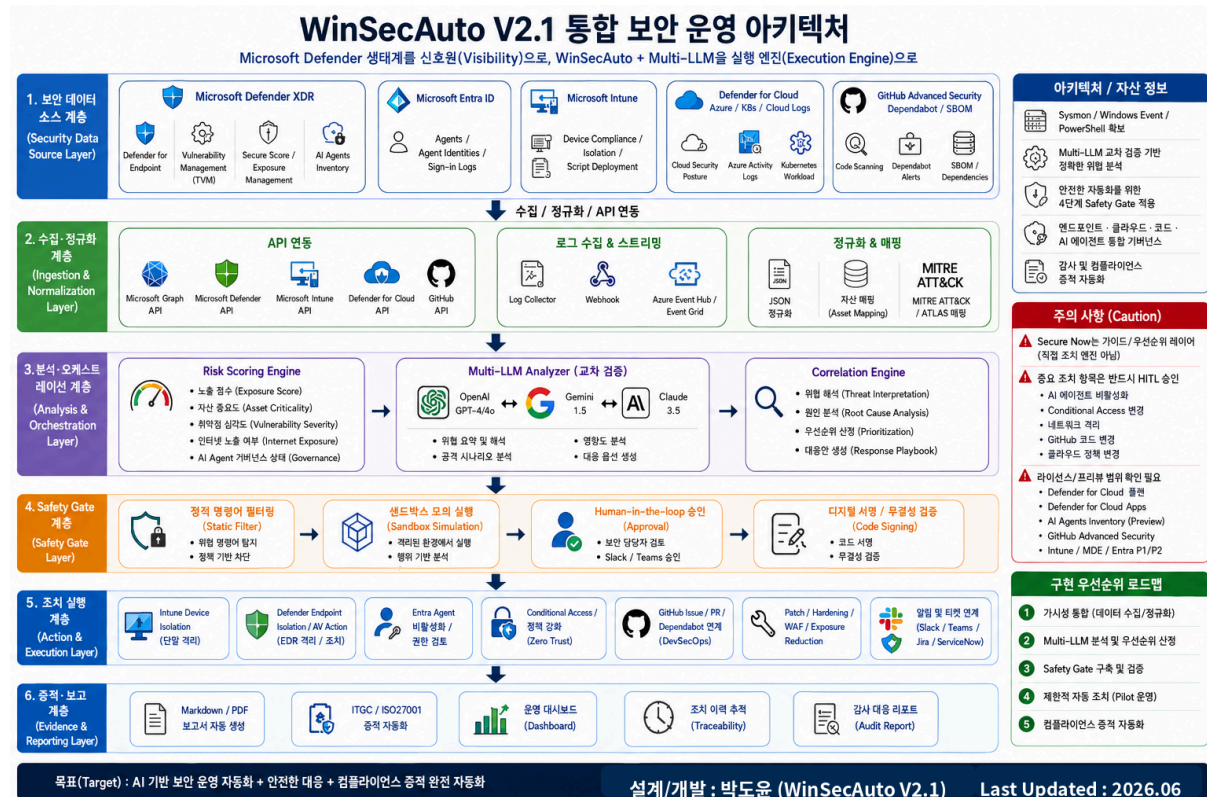
4단계 : 제한적 조치

- Intune 정책 Push
- 네트워크 차단 격리
- 방화벽 차단
- Slack / 메일 알림

5단계 : 감사증적 자동화

- 탐지, 분석, 승인, 조치, 결과를 Markdown/PDF로 자동 저장

[After 프로젝트명] WinSecAuto V2.1: Microsoft Defender 기반 AI 보안 운영 자동화 아키텍처



1. 프로젝트 개요

WinSecAuto V2.1은 Microsoft Defender XDR, Entra ID, Intune, Defender for Cloud, GitHub Advanced Security, SBOM 데이터를 통합하여 보안 이벤트·취약점·클라우드 노출·AI 에이전트 거버넌스 상태를 하나의 파이프라인에서 분석하는 AI 기반 보안 운영 자동화 아키텍처입니다.

기존 WinSecAuto V2.0이 Defender EDR, 클라우드 로그, Multi-LLM 교차 검증, Safety Gate, Intune 기반 단말 격리, 감사 증적 자동화에 초점을 두었다면, V2.1은 Microsoft Defender의 Secure Score, Exposure Management, AI Agents Inventory, Entra Agent Identity, Defender for Cloud, GitHub/SBOM 영역까지 확장하여 보안 운영 전반의 가시성·우선순위·조치·증적화를 통합하는 구조로 고도화 했습니다.

2. 설계 목적

본 아키텍처는 보안 담당자가 여러 포털에서 개별적으로 확인해야 하는 보안 신호를 통합하고, AI 기반 분석을 통해 실제 조치 가능한 대응 흐름으로 연결하는 것을 목표로 합니다.

주요 목적은 다음과 같습니다.

- Defender 기반 보안 이벤트, 취약점, 노출 정보 통합
- Entra ID 기반 AI Agent Identity 및 Sign-in Logs 관리
- Intune 기반 단말 상태 확인, 스크립트 배포, 격리 조치 연계
- Defender for Cloud 기반 Azure / K8s / Cloud Logs 분석
- GitHub Advanced Security, Dependabot, SBOM 기반 오픈소스 취약점 영향도 분석
- Multi-LLM 기반 위협 교차 검증 및 대응안 생성
- Safety Gate 기반 안전한 자동 조치 통제
- ITGC / ISO27001 감사 대응을 위한 Markdown/PDF 증적 자동화

3. 아키텍처 구성

1) 보안 데이터 소스 계층

Microsoft Defender XDR, Entra ID, Intune, Defender for Cloud, GitHub Advanced Security, SBOM, Sysmon, Windows Event, PowerShell 로그를 주요 데이터 소스로 구성했습니다.

이 계층은 엔드포인트, 클라우드, ID, 코드, 오픈소스, AI 에이전트 영역에서 발생하는 보안 신호를 수집하는 역할을 합니다.

2) 수집·정규화 계층

Graph API, Defender API, Intune API, Defender for Cloud API, GitHub API를 통해 데이터를 수집하고 JSON 형태로 정규화합니다.

수집된 데이터는 자산 중요도, 취약점 심각도, 인터넷 노출 여부, MITRE ATT&CK / ATLAS 매핑 정보와 연결하여 분석 가능한 형태로 변환합니다.

3) 분석·오케스트레이션 계층

Risk Scoring Engine, Multi-LLM Analyzer, Correlation Engine으로 구성됩니다.

Risk Scoring Engine은 노출 점수, 자산 중요도, 취약점 심각도, 인터넷 노출 여부, AI Agent 거버넌스 상태를 기준으로 위험도를 산정합니다.

Multi-LLM Analyzer는 OpenAI, Gemini, Claude를 활용해 단일 모델의 판단 편향을 줄이고, 위협 요약, 영향도 분석, 공격 시나리오 분석, 대응 옵션 생성을 수행합니다.

Correlation Engine은 수집된 이벤트와 위험 점수를 기반으로 원인 분석, 우선순위 산정, 대응안 생성을 수행합니다.

4) Safety Gate 계층

AI 기반 자동 조치의 위험성을 줄이기 위해 4단계 Safety Gate를 적용했습니다.

- 정적 명령어 필터링
- 샌드박스 모의 실행
- Human-in-the-loop 승인
- 디지털 서명 및 무결성 검증

이를 통해 AI가 생성한 대응 명령이나 스크립트가 즉시 실행되지 않도록 통제하고, 보안 담당자 승인 후 제한적으로 조치가 수행되도록 설계했습니다.

5) 조치 실행 계층

검증이 완료된 대응안은 Intune, Defender Endpoint, Entra ID, Conditional Access, GitHub, Slack, Teams, Jira, ServiceNow와 연계됩니다.

주요 조치 항목은 다음과 같습니다.

- Intune 기반 단말 격리
- Defender Endpoint Isolation 및 AV 조치
- Entra Agent 권한 점검 및 비활성화 검토
- Conditional Access 정책 강화
- GitHub Issue / PR / Dependabot 연계
- Patch / Hardening / WAF / Exposure Reduction
- Slack / Teams / Jira / ServiceNow 알림 및 티켓 생성

6) 증적·보고 계층

탐지, 분석, 승인, 조치, 결과 확인 과정을 Markdown/PDF 형태의 보고서로 자동 생성합니다.

이를 통해 보안 운영 결과를 단순 로그가 아닌 ITGC, ISO27001, 내부 감사 대응 가능한 증적 자료로 관리할 수 있도록 설계했습니다.

4. 핵심 차별점

본 아키텍처의 핵심 차별점은 Microsoft Defender 생태계를 단순 모니터링 도구가 아니라, 보안 운영 자동화를 위한 신호원으로 활용했다는 점입니다.

Microsoft Defender 계열은 자산 가시성, 취약점 정보, 노출 관리, 권장 조치, 클라우드·ID·엔드포인트 보안 신호를 제공합니다. WinSecAuto는 이 신호를 수집·정규화하고, Multi-LLM 분석과 Safety Gate를 거쳐 실제 조치 가능한 대응안과 감사 증적을 생성합니다.

즉, Microsoft Defender가 “무엇이 위험한지”를 식별하고, WinSecAuto가 “어떻게 분석하고, 검증하고, 조치하고, 증적화할지”를 담당하는 구조입니다.

5. 기대효과

- 보안 이벤트, 취약점, 클라우드 노출, AI 에이전트 정보를 통합 관리
- Exposure Management 기반 위험 우선순위 자동화
- Multi-LLM 교차 검증을 통한 위협 분석 품질 향상
- Safety Gate를 통한 AI 자동화 리스크 통제
- Intune, Defender, Entra ID 기반 제한적 자동 조치 구현
- GitHub/SBOM 기반 DevSecOps 보안 점검 확장
- ITGC / ISO27001 감사 대응을 위한 증적 자동화
- 보안 운영, 취약점 관리, 클라우드 보안, AI Agent Governance, 컴플라이언스를 하나의 파이프라인으로 연결

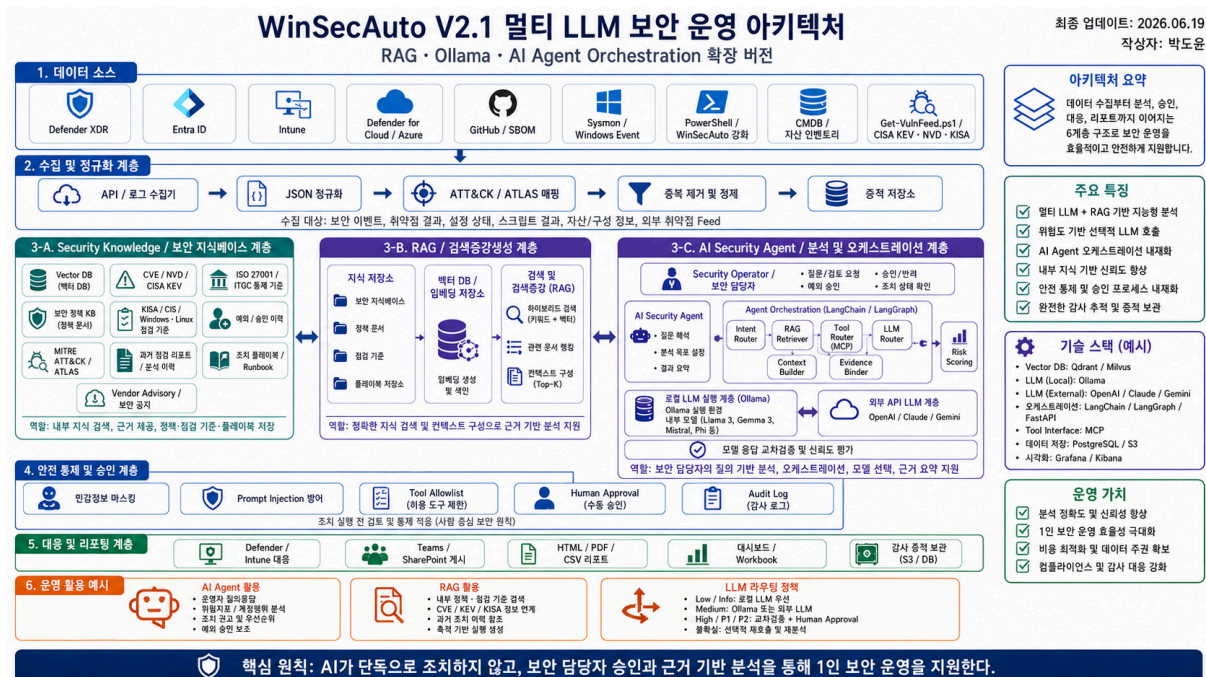
6. 사용 기술

- Microsoft Defender XDR
- Microsoft Defender for Endpoint
- Microsoft Defender Vulnerability Management
- Microsoft Security Exposure Management
- Microsoft Entra ID

- Microsoft Intune
- Defender for Cloud
- Azure / Kubernetes Logs
- GitHub Advanced Security
- Dependabot
- SBOM
- PowerShell
- Microsoft Graph API
- Defender API
- Intune API
- Slack / Teams Webhook
- OpenAI API
- Gemini API
- Claude API
- MITRE ATT&CK
- MITRE ATLAS
- Markdown / PDF Report Automation

7. 프로젝트 상태

- 프로젝트명: WinSecAuto V2.1 통합 보안 운영 아키텍처
- 진행 기간: 2026.06 ~ 진행 중
- 상태: 아키텍처 설계 및 PoC 고도화 단계
- 목표: AI 기반 보안 운영 자동화, 안전한 대응 통제, 컴플라이언스 증적 자동화



아키텍처 요약:

WinSecAuto V2.1은 Defender XDR, Entra ID, Intune, Defender for Cloud, GitHub/SBOM, Sysmon, Windows Event, PowerShell 로그, 자산 인벤토리 데이터를 수집하고 JSON으로 정규화한 뒤, RAG 기반 보안 지식베이스와 LLM 라우팅 구조를 통해 위험도와 조치 우선순위를 분석하는 보안 운영 자동화 아키텍처입니다.

RAG 계층은 내부 보안 정책, ISO27001/ITGC 통제 기준, KISA/CIS 점검 기준, MITRE ATT&CK/ATLAS, CVE/NVD/CISA KEV, 과거 점검 리포트와 예외 승인 이력을 검색하여 AI 분석의 근거를 제공합니다.

이를 통해 LLM이 단순 추론에 의존하지 않고, 실제 운영 기준과 감사 증적에 기반한 분석을 수행할 수 있도록 설계했습니다.

멀티 LLM은 모든 이벤트에 대해 상시 병렬 실행하지 않고 위험도와 불확실성에 따라 선택적으로 호출합니다.

Low/info 항목은 룰 기반 분석과 RAG 요약으로 처리하고 High/P1/P2 또는 판단이 불확실한 항목만 외부 LLM을 통해 교차 검증합니다. Ollama 기반 Local LLM은 민감 로그의 1차 요약, 마스킹, 내부 정책 기반 분류, 오프라인 PoC 테스트에 활용합니다.

조치 실행 전에는 민감정보 마스킹, Prompt Injection 방어, Tool Allowlist, Human Approval, Audit Log로 구성된 안전 통제 계층을 적용합니다. 최종 결과는 Defender/Intune 대응, Teams 또는 티켓 연동, HTML/PDF/Markdown 리포트, 대시보드 지표, 감사 증적 보관으로 연결됩니다.

핵심 원칙은 "모든 이벤트를 멀티 LLM으로 상시 병렬 처리하지 않고, 위험도와 불확실성에 따라 선택적으로 호출한다"는 것입니다.

추가 사용 기술:

RAG (Retrieval-Augmented Generation)

보안 정책, ISO27001/ITGC 통제 기준, KISA/CIS 점검 기준, MITRE ATT&CK/ATLAS, CVE/NVD/CISA KEV, 과거 점검 리포트와 예외 승인 이력을 검색하여 AI 분석의 근거로 활용.

Vector Database

보안 지식베이스, 점검 기준, 조치 이력, 예외 승인 이력, 취약점 정보를 임베딩하여 검색하기 위한 벡터 저장소 구성

PoC 단계에서는 Chroma 또는 FAISS 기반 구조를 고려하고, 운영화 시 Azure AI Search, PostgreSQL pgvector, Qdrant, Milvus 등으로 확장 가능

Embedding Model

보안 정책 문서, 점검 기준, 리포트, 조치 이력을 벡터화하여 유사도 기반 검색과 근거 연결에 활용

Ollama

민감 로그를 외부 LLM API로 전송하기 전 로컬 환경에서 1차 요약, 마스킹 분류, 오프라인 PoC 테스트를 수행하기 위한 Local LLM 실행 환경

Local LLM

Llama 3, Mistral, Phi 계열 모델을 활용한 로컬 분석 구조 검토

비용 절감, 민감정보 보호, 외부 API 의존도 감소 목적

LLM Router

위험도와 불확실성에 따라 Local LLM, 단일 외부 LLM, Multi-LLM 교차 검증 여부를 선택하는 라우팅 구조

MCP (Model Context Protocol)

LLM이 승인된 보안 도구와 API만 호출할 수 있도록 통제하는 도구 연동 계층 Defender API, Intune Graph API, GitHub/SBOM, Log Analytics, 리포트 생성기, Teams 또는 티켓 시스템 연동 구조로 확장 가능

Prompt Injection Defense

RAG 검색 결과와 외부 입력이 LLM 판단을 오염시키지 않도록 프롬프트 인젝션 방어, 도구 호출 제한, 입력 검증 로직 적용

Tool Allowlist

LLM이 임의의 명령이나 API를 실행하지 못하도록 승인된 도구만 호출 가능한 Allowlist 기반 통제 구조

Source Citation / Evidence Binding

AI 분석 결과에 내부 정책, ATT&CK, CVE, 과거 리포트, 예외 승인 이력 등 근거 출처를 연결하여 감사 대응 가능한 설명 구조 제공

Token and Cost Logging

외부 LLM API 사용 시 토큰 사용량, 호출 모델, 호출 사유, 비용 추정치를 기록하여 운영 비용을 통제하는 구조

Azure AI Search 또는 PostgreSQL pgvector

운영화 단계에서 RAG 검색 성능과 보안 지식베이스 관리를 위해 적용 가능한 벡터 검색 저장소 후보

아키텍처 보완 설명:

본 아키텍처는 AI가 독립적으로 보안 조치를 수행하는 구조가 아닌, 1인 보안 담당자의 판단을 보조하는 AI Security Agent 기반 보안 운영 지원 구조입니다.

보안 담당자가 자연어로 점검 결과, 취약점 Feed, 자산 인벤토리, 과거 리포트, 예외 승인 이력에 대해 질의하면, AI Agent는 LangChain 또는 LangGraph 기반 Orchestration Layer를 통해 필요한 데이터와 도구를 선택합니다.

이후 RAG 기반 보안 지식베이스, CISA KEV/NVD/KISA/Vendor Advisory, WinSecAuto 점검 결과, Defender/Intune/Entra/GitHub/SBOM 데이터를 연결하여 근거 기반의 위험 요약, 조치 우선순위, 담당자별 조치 항목을 생성합니다.

LLM은 모든 이벤트에 대해 상시 병렬 호출하지 않고, 위험도와 불확실성에 따라 선택적으로 사용합니다. Low/Info 항목은 룰 기반 분석과 RAG 요약으로 처리하고, Medium 항목은 Ollama Local LLM 또는 단일 외부 LLM을 사용하며, High/P1/P2 또는 판단이 불확실한 항목만 외부 LLM 교차 검증과 Human Approval을 거치도록 설계했습니다.

조치 실행 전에는 민감정보 마스킹, Prompt Injection 방어, Tool Allowlist, Human Approval, Audit Log로 구성된 Safety Gate를 적용합니다. 이를 통해 AI가 임의로 명령을 실행하지 않고, 보안 담당자의 승인과 근거 기반 분석을 통해 제한적으로 조치가 수행되도록 통제합니다.

결과적으로 본 구조는 1인 보안 운영 환경에서 여러 보안 포털과 점검 결과를 수동으로 확인해야 하는 부담을 줄이고 AI Agent가 근거 수집, 위험도 분석, 우선순위 제언, 보고서 생성을 지원하는 보안 운영 보조 아키텍처입니다.

ISMS-P · CSAP 대응을 위한 LLM 기반
쿠버네티스 클러스터 보안 진단 프레임워크

박도윤^{1*}, 이형규^{1*}, 임윤태^{1*}, 이재환^{1*}
네이버 클라우드 캠프¹, 이스트 소프트²

LLM-Based Kubernetes Cluster Security Diagnostics Framework
for ISMS-P and CSAP Compliance

Do-Yun Park^{1*}, Hyeong-Gyu Lee^{1*}, Yun-Tae Yim^{1*}, Jae-Hwan Lee^{1*}

요약 : 본 논문은 쿠버네티스 클러스터 환경을 사용하는 중소규모의 기업체가 CSAP와 ISMS-P 기준을 만족하는 보안 체계를 효과적으로 수립할 수 있게 손쉬운 보안 점검 자동화 프레임워크를 제안한다. 쿠버네티스 클러스터 환경에 자동으로 배포되는 정적 점검 도구와 동적 탐지 도구 그리고 상용 LLM으로 구성된 자동화 보안 점검 프레임워크를 통해 보안 인증 취득에 요구되는 최소한의 보안 체계를 쉽게 구축하고, 보안 전문 인력이 부족한 중소기업도 효율적으로 클라우드 환경의 보안 진단을 할 수 있다.

Key Words : 중소기업, 클라우드 클러스터 환경, 쿠버네티스, 정적·동적 분석, 보안 점검, CSAP, ISMS-P

1. 서론

클라우드 인프라의 확산과 컨테이너 기반 아키텍처의 보편화로 인해, 쿠버네티스를 중심으로 한 클라우드 네이티브 환경은 서비스의 민첩성과 확장성을 제공하는 핵심 기술로 자리잡고 있다^[1]. 그러나 이러한 환경은 구조적 복잡성과 지속적인 상태 변화로 인해 기존의 정적 보안 점검 방식만으로는 실시간 위협에 효과적으로 대응하기 어렵다.

이와 같은 한계를 보완하기 위해 한국인터넷진흥원(KISA)은 ISMS-P (정보보호 및 개인정보보호 관리체계)와 CSAP (클라우드 서비스 보안 인증제도)인증 제도를 통해 클라우드 보안 기준을 제시하고 있으나, 두 인증 제도 모두 고정된 인프라를 전제로 구성되어 있어 유동적인 클라우드 환경에는 적용에 한계 및 제약이 있다^[2, 3]. 특히 보안 인력이 부족한 중소기업의 경우 초기 서버 환경을 직접 구성하는 단계에서부터 어려움을 겪으며, 이후 제시된 보안 기준을 운영 환경에 현실적으로 적용하고 운영하는 데에도 상당한 제약이 따른다^[4].

본 연구는 쿠버네티스 클러스터를 대상으로 정적 분석 도구와 동적 보안 탐지 도구를 연계한 자동화 보안 진단 시스템을 제안한다. 또한, 상용 LLM을 활용한 보고서 자동화 기능을 통해 보안 전문성이 부족한 인력도 진단 결과를 직관적으로 이해하고, ISMS-P 및 CSAP 기준에 따라 효과적으로 보안 위협에 대응할 수 있도록 설계하였다.

2. 이론적 배경

2.1 ISMS-P와 CSAP의 보안 요구사항

본 연구에서는 ISMS-P가 제시하는 관리 체계, 보호 대책, 개인정보 처리 단계별 요구사항과 CSAP의 SaaS 표준 기준을 보안 점검 기준으로 선정하였다.

Table 1. Among the ISMS-P Protective Measures Requirements List

2.9.1 보안시스템 유형별로 관리자 지정, 최신 정책 업데이트, 쿼셋 변경, 이벤트 모니터링 등의 운영절차를 수립·이행하고 보안시스템별 정책적용 현황을 관리하여야 한다.
2.9.2 클라우드 서비스 이용 시 서비스 유형(SaaS, PaaS, IaaS 등)에 따른 비인가 접근, 설정 오류 등에 따라 중요정보와 개인정보가 유·노출되지 않도록 관리자 접근 및 보안 설정 등에 대한 보호대책을 수립·이행하여야 한다. 행하여야 한다.
2.9.3 외부 네트워크에 공개되는 서버의 경우 내부 네트워크와 분리하고 취약점 점검, 접근통제, 인증, 정보 수집·저장·공개 절차 등 강화된 보호대책을 수립·이행하여야 한다.

Table 2. Among the CSAP Network Security List

인증 기준	클라우드컴퓨팅서비스와 관련된 내·외부 네트워크에 대해 보안정책과 절차를 수립하여야 한다.
점검 목록	공통 1) 내·외부 네트워크를 통한 클라우드 시스템의 접근을 통제하는 보안 정책이 수립되어 있는가?
관련 법규	- 개인정보 보호법 제29조 (안전조치 의무) - 개인정보의 안전성 확보조치 기준 제6조 (접근통제) - 국가 정보보호 기본지침 제40조 (내부망·인터넷망 분리), 제59조 (원격근무 보안)

2.2 기존 인증 방식의 보안 한계 극복

ISMS-P는 개인정보의 수집부터 파기까지의 전 과정을 관리하는 통제 체계를, CSAP는 클라우드 서비스의 보안을 계층별(SaaS, PaaS, IaaS)로 평가하는 기준을 제시한다. 그러나 이들 인증 제도는 자원이 동적으로 생성·변경되는 클라우드 네이티브 환경에는 적절히 대응하기 어렵다.

이러한 한계를 극복하기 위해 본 연구는 쿠버네티스 기반 클러스터를 대상으로 정적 점검 (kube-bench, kubescape, Syft, Gripe)과 동적 탐지 (Falco, Suricata)를 결합한 자동화 보안 진단 프레임워크를 제안한다. 본 시스템은 클러스터 내에서 발생하는 보안 이벤트 및 설정 정보를 Filebeat를 통해 수집하고, Elasticsearch에 저장한 후 Kibana를 통해 데이터를 시각화한다. 수집된 데이터는 ISMS-P 및 CSAP의 평가 항목과 자동으로 연계되어 실시간 위험 탐지와 기준 기반의 보안 점검을 동시에 수행할 수 있으며, 이를 통해 보안 인프라 관리 체계의 구축과 운영을 효과적이고 지속 가능하도록 구현할 수 있다.

3. 기술적 배경

3.1 통합 보안 시스템 구성도

제안된 보안 진단 시스템은 사용자의 쿠버네티스 클러스터에 배포되는 점검 도구와, 수집된 데이터를 처리 및 분석하는 중앙 Main Server로 구성된다. 점검 도구는 클러스터 내에 설치된 정적 점검 도구와 동적 탐지 도구를 활용하여 설정 기반의 보안 취약점과 실시간 위험 요소를 탐지한다. 특히 동적 탐지 도구에서 탐지된 정보는 중앙 서버로 전송된다. Main Server는 수신한 정보를 시각화 하여 클러스터의 실시간 보안 상태를 대시보드 형태로 제공한다.

본 시스템은 테스트 인프라를 구성한 뒤 다양한 시나리오를 적용하여 실효성과 안정성을 검증하였고, 자동화된 보안 진단 및 위험 대응이 가능함을 입증하였다. 전체 구성 요소와 기능적 역할을 포함한 데이터 흐름은 Fig 1에 상세히 나타나 있다.

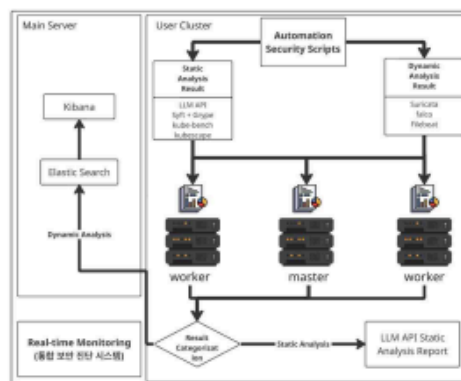


Fig. 1. System Architecture Diagram

3.2 메인 서버의 보안 로그 통합 및 분석 구조

Main Server는 Elasticsearch와 Kibana로 구성되며 동적 탐지 로그의 수집, 검색, 및 실시간 시각화를 지원한다. 다음은 정적 점검 도구와 동적 탐지 도구의 역할을 나타낸다.

정적 점검 도구는 사용자 클러스터 내 배포되어 Kubernetes의 구성 파일, 보안 정책, 이미지 취약점 등 점검 결과를 사용자 서버 내에 저장한다.

동적 탐지 도구는 클러스터 실행 중 발생하는 시스템 호출, 네트워크 트래픽 등 실시간 이벤트 로그를 감지한다. 이후 Filebeat를 통해 JSON 형식으로 Main Server의 Elasticsearch에 인덱싱되며 Kibana 대시보드를 통해 다양한 실시간 보안 이벤트를 시각화하고 추적할 수 있다.

또한, 저장된 정적 점검 결과는 사용자 서버 내의 Python 스크립트를 통해 상용 LLM API와 연동되어 ISMS-P와 CSAP 기준에 맞게 분석 및 요약된다.

3.3 정적 점검 기반 보안 구성 사전 점검

정적 점검 도구는 쿠버네티스 클러스터 내 모든 노드와 컨테이너를 대상으로 정적 보안 점검을 수행하며, 스크립트 실행 시 네임스페이스 지정과 기능별 선택 설치 또는 전체 자동 설치가 가능하다. 설치되는 점검 도구 Syft, Gripe, Kubescape, Kube-bench를 조율하여 보안 적합성을 평가한다.

Syft와 Gripe는 컨테이너 이미지 내부의 소프트웨어 패키지를 식별하고, 해당 구성 요소에 대해 공통 취약점 목록 (CVE)을 기반으로 보안 취약점을 진단하며, 정책 위반 여부를 함께 평가한다.

Kubescape는 IaC 정의, 네트워크 보안 정책, RBAC 구성을 분석하여 클러스터 수준의 보안 위험을 시각적으로 표현하여 포괄적인 진단 결과를 제공한다.

Kube-bench는 클러스터의 주요 컴포넌트에 대해 CIS Kubernetes Benchmark 기준에 따라 설정의 안전성과 적절성을 점검한다.

아래 Fig 2는 점검 도구 중 Kube-bench의 점검 화면 중 일부의 캡처본이다.

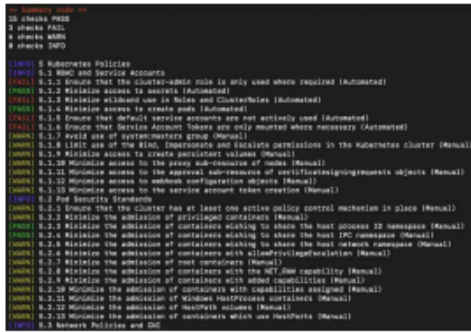


Fig. 2. Among the Kube-bench results

3.4 LLM을 활용한 보고서 작성

보안 진단을 완료한 점검 도구는 결과를 JSON 형식으로 저장하고, 이를 상용 LLM API에 전송하여 보고서를 생성한다. LLM은 수신된 데이터를 ISMS-P 및 CSAP 기준에 맞춰 분석하고, 정제된 템플릿을 기반으로 핵심 내용을 요약하여 관리자가 직관적으로 이해할 수 있는 형식의 보고서를 출력한다.

LLM의 활용으로 대용량 로그와 기술적 정보를 구조화하여 핵심 취약점과 우선 조치 항목을 효과적으로 도출한다. 또한, 용어 통일과 자동 번역을 통해 보고서의 품질을 높여 보안 비전문가도 전체 보안 상황을 파악하고 대응할 수 있도록 지원한다.

Fig 3는 이러한 LLM 기반 자동 생성 보고서의 실제 예시이다.

🔍 Kube-Bench 보안 진단 보고서

발행 일자: 2025-05-15 22:00

분석 대상: Kubernetes Cluster (종 3개 노드)

1. 개요

2025년 05월 15일 22시에 Kubernetes 클러스터에 대한 kube-bench 보안 진단을 수행했습니다. 총 3개의 노드(master-node-001, master-node-002, worker-node-001)를 대상으로 14개의 보안 점검 항목을 분석하였습니다. 분석 결과, 평가되어 보안 위험이 발견되어 긴급한 조치가 필요합니다. 특히, API 서버 및 kubelet 구성과 관련된 심각한 취약점(S1) 및 중대한 결함(S2) 항목들이 다수 발견되었습니다. K8AC 및 시스 커스텀 관련 설정에서도 심각한 문제가 확인되었습니다.

2. 주요 진단 결과 요약

전체 준수율: 10%

✓ 점검 (PASS): 0

✗ 미점검 (FAIL): 10

⚠ 경고 (WARN): 12

3. 핵심 보안 이슈

• API 서버 구성 오류: API 서버의 인증 모듈(authentication)이 kubelet 인증서 기반 설정(kubelet-certificate-authority)로 설정되어 있어, 인증이 제대로 작동하지 않습니다. 이는 심각한 보안 취약점입니다. (S1) (중요: 인증 모듈이 올바르게 설정되어 있는지 확인하고, kubelet 인증서 기반 설정으로 변경해야 합니다.)

Fig. 3. Sample Inspection Results Report

3.5 동적 탐지를 통한 실시간 데이터 수집

동적 탐지 도구는 쿠버네티스 클러스터 내에서 발생하는 런타임 이벤트를 실시간으로 수집하고 분석하는 기능을 수행한다. 클러스터에 배포된 Filebeat를 활용하여 보안 이벤트를 수집하고, Main Server로 전송함

으로써 실시간 위험 분석이 가능하도록 한다.

Falco는 커널 수준에서 시스템 호출을 모니터링하여 컨테이너 내부에서 발생하는 비정상적 행위를 감지하며, Suricata는 네트워크 패킷을 심층적으로 검사하여 잠재적인 공격 시도를 탐지 및 차단한다.

이 두 도구가 결합된 동적 탐지 프레임워크는 컨테이너 기반 클라우드 환경의 예측 불가능한 보안 위협을 신속히 감지하고 분류하여 실시간 대응 체계를 지원한다.

Fig 4은 Suricata가 탐지한 공격 시그니처 사례로, 시도된 비정상 행위가 대시보드를 통해 시각적으로 확인되는 모습을 보여준다.

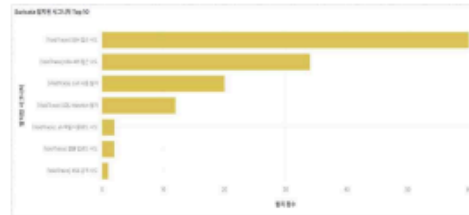


Fig. 4. Top 10 Curated Examples of Suricata Detection Signatures

3. 결론

본 연구는 클라우드 네이티브 환경을 도입한 중소기업에서도 효율적인 보안 진단과 위험 대응이 가능하도록 자동화된 보안 점검 체계를 제안하였다. 중앙 서버로 수집된 정적 점검, 동적 탐지 데이터를 시각화 도구와 상용 LLM을 통해 ISMS-P와 CSAP 기준에 부합하는 점검 결과를 제공하여 보안 인력이 부족한 중소기업 및 현업에서도 직관적이고 신속한 대응이 가능한 보안 체계 구현이 가능함을 확인하였다.

향후에는 머신러닝 기반 이상 탐지 기술을 적용하여 탐지 정확도와 민감도를 향상시키고, 개인정보 보호 규제 대응 및 다양한 실험환경에서의 안정성과 확장성 확보를 목표로 한다.

참고문헌

- [1] 퓨어스토리지(Pure Storage)와 디멘셔널 리서치(Dimensional Research), 2024, "2024년 쿠버네티스 전문가의 견해 보고서: 기업의 미래를 주도하는 데이터 트렌드", 퓨어스토리지.
- [2] 한국인터넷진흥원, 2024, "ISMS-P 인증제도 안내서(2024.07)", Available at: <https://isms.kisa.or.kr/main/ispims/notice/>.
- [3] 한국인터넷진흥원, 2024, "클라우드 보안인증제", Available at: <https://isms.kisa.or.kr/main/csap/intro/index.jsp>.
- [4] 한국인터넷진흥원, 2024, "2024년 정보보호 실태조사", 한국인터넷진흥원.